VE02 : Statische Analyse

App wird analysiert, OHNE sie auszuführen

① APK - Grundlagen

- Eine APK ist ein ZIP-Archiv. Header beginnt mit `Soub`
- Code liegt als `classes.dex` (DEX-Bytecode) vor.
- Manifest (`AndroidManifest.xml`) und Ressourcen (`resources.arsc`) sind binär und müssen dekodiert wird.
- Tool zum Entpacken: `unzip app.apk`

② Dekompilieren (jadx vs. Smali):

- Jadx - gui: Wandelt DEX in lesbares Java um. Achtung: Es ist nicht der Original-Code und nicht kompilierbar (Jadx muss Namen von Variablen/Konstanten erraten)
- Smali (Apktool): Wandelt DEX in exakten Text um. Nur hier können wir den Code für Patches sicher bearbeiten (`apktool d/b`)

③ Das Manifest (Die Angriffsfläche):

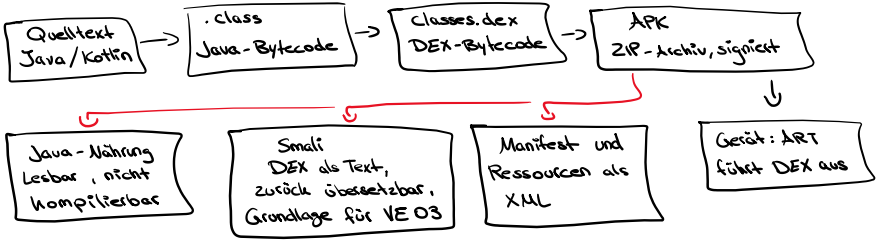
- `android:exported="true"`: Andere Apps (oder adb) können z.B. `.StaffActivity` direkt aufrufen und Prüfungen überspringen.
- `android:usesCleartextTraffic="true"`: App darf unverschlüsseltes HTTP nutzen.

④ Smali Lesen:

- `v0` `v1` = lokale Register; `p0`, `p1` = Parameter (`p0` ist oft `this`)
- `iget` / `iput` = Variable Lesen / schreiben.
- `invoke-virtual` = Methode aufrufen. Ergebnis holen mit `move-result`.

`if-lt -v0, v1, :cond_0` = Wenn `v0 < v1`, springe zur Marke `:cond_0`

Warum Jadx nicht den Original-Code liefert und wann du Apktool brauchst.



VE03 : Patchen und Instrumentieren

Code wird VERÄNDERT (Patchen) oder dynamisch manipuliert (Frida)

Konstanten:

- `const/16 v0, 0x64` -> `0x64` ist Hexadezimal für den Score 100.
- `const/16` größer als `const/4`

Commands zum Patchen

Nachdem der Smali-Code geändert wurde, müssen diese Schritte folgen.

① Bauen: `aptotool b ordner -o unsigned.apk`
(Packt den geänderten Smali-Code wieder in eine APK.)

② Ausrichten: `zipalign -p 16 -f 4 unsigned.apk aligned.apk`
(Muss vor dem Signieren passieren! Richten Daten im ZIP aus.

③ Signieren: `apksigner sign --ks key.keystore --out patched.apk aligned.apk` (Die App bekommt eine Identität, da die alte durch unsere Änderungen ungültig wurde.

④ Prüfen: `apksigner verify --verbose patched.apk`
(Kontrolliert, ob die Signatur gültig ist)
Die alte App vorher mit `adb uninstall` Löschen, da Updates mit fremden Signaturschlüssel verweigert werden!)

Dynamische Instrumentierung

Manipuliert die App live im Arbeitsspeicher. Die APK-Datei wird dabei NICHT verändert!

- Beobachten (Trace): Frida liest heimlich Daten mit, lässt danach aber den echten Original-Code ganz normal weiterlaufen.
- Verändern (Hook): Frida grätscht dazwischen und erzwingt eine eigene Antwort (z.B. `return 1337`). Der echte Code der App wird ignoriert.
- Die Grenze (Nachteil): Neustart = Reset. Sobald die App ohne Frida neu gestartet wird, ist der Hack sofort weg, da die APK nie umgeschrieben wurde.